ĐIỂM YẾU CỦA HỆ THỐNG

& LỜI NÓI VỚI THẦY KHI PHẢN BIỆN

Tài liệu này liệt kê những hạn chế THẬT SỰ của hệ thống Malware Analysis Platform, kèm theo cách lựa lời để trả lời thầy một cách trung thực, khiêm tốn nhưng thể hiện được sự hiểu sâu. Nguyên tắc: thành thật nhận khuyết điểm + biết đúng hướng khắc phục là cách ghi điểm cao nhất khi bảo vệ.

Bảng tổng quan 7 điểm yếu

#	Điểm yếu	Mức độ	Hướng khắc phục
1	Chỉ phân tích tĩnh (không động)	Rất lớn	Sandbox (Cuckoo/CAPE)
2	Dựa chữ ký → dễ bị obfuscation vượt	Rất lớn	Phân tích động + ML
3	Không bắt được mã độc mới (zero-day)	Lớn	Học máy
4	Không tự unpack mã đóng gói	Trung bình	Unpacker (UPX)
5	YARA không chạy trên host free	Trung bình	Deploy Docker/trả phí
6	Chỉ luật cứng, không học máy	Lớn	Tích hợp ML
7	Báo nhầm (false positive)	Thường gặp	Tinh chỉnh rule + whitelist

Chi tiết từng điểm yếu & lời nói

ĐIỂM YẾU 1: Chỉ phân tích TĨNH, không có phân tích ĐỘNG

Vấn đề:

Hệ thống chỉ "đọc" file, không chạy thử. Mã độc hiện đại thường tự biến đổi khi chạy (polymorphic / metamorphic) — lúc đứng yên vô hại, lúc chạy mới lộ mặt. Nên có mã độc nằm im cũng không tra ra.

Trả lời thầy (lựa lời):

> *Dạ đúng, đây là hạn chế lớn nhất của em. Em mới làm được phân tích tĩnh. Những mã độc tự thay đổi khi chạy thì em bắt không được, vì em không cho nó chạy. Để khắc phục, hướng đi là gắn sandbox (Cuckoo/CAPE) — nhưng do thời gian có hạn nên em chưa làm được phần đó.*

ĐIỂM YẾU 2: Dựa vào CHỮ KÝ → dễ bị vượt bằng obfuscation

Vấn đề:

Chỉ cần xé chuỗi ("sys"."tem"), mã hóa (base64_decode), hay làm rối mã → chữ ký không khớp → lọt lưới. Nhưng ý nghĩa độc hại vẫn y nguyên. Đây chính là điều thầy đã chỉ ra.

Trả lời thầy (lựa lời):

> *Thầy nói rất đúng. Em dùng cơ chế chữ ký (regex + YARA), nên bản chất có thể bị qua mặt bằng obfuscation — em đã tự thử và thấy nó lọt thật. Đây là giới hạn cố hữu của mọi hệ thống dựa chữ ký. Hướng khắc phục của ngành là phân tích động (xem hành vi thật) hoặc học máy (học đặc trưng, không so chữ ký).*

ĐIỂM YẾU 3: Chỉ nhận diện MẪU ĐÃ BIẾT, không phát hiện mã độc MỚI (zero-day)

Vấn đề:

YARA rules và regex do người viết "đoán trước" mã độc trông thế nào. Nên chỉ bắt được những gì ta đã biết. Mã độc hoàn toàn mới (chưa ai gặp) thì hệ thống không nhận ra.

Trả lời thầy (lựa lời):

> *Dạ, hệ thống em theo trường phái nhận diện chữ ký, nên chỉ bắt được mã độc đã biết khuôn mẫu. Mã độc hoàn toàn mới thì em không phát hiện vì chưa có rule nào khớp. Muốn bắt cả mã mới phải dùng học máy hoặc phân tích hành vi — em ghi trong phần hướng phát triển.*

ĐIỂM YẾU 4: Không tự UNPACK mã đã đóng gói

Vấn đề:

Với file bị pack, hệ thống chỉ phát hiện "entropy cao = nghi packer" rồi dừng lại, không mở gói ra phân tích. Phần "ruột" mã độc vẫn mù mịt.

Trả lời thầy (lựa lời):

> *Em mới dừng ở việc NHẬN RA file bị pack (qua entropy), chứ chưa unpack được. File upx_packed mà em demo, em chỉ kết luận 'nghi packed' chứ chưa xem được bên trong. Hướng phát triển là tích hợp unpacker (UPX unpack) để lột lớp vỏ rồi phân tích tiếp.*

ĐIỂM YẾU 5: YARA không chạy được trên host free

Vấn đề:

Ở máy local YARA chạy ngon. Nhưng deploy lên Render (miễn phí) thì yara-python KHÔNG cài được (thiếu libyara C), nên backend trên web thực tế thiếu mất lớp YARA.

Trả lời thầy (lựa lời):

> *Có một hạn chế về triển khai: trên môi trường web em deploy (Render free) không cài được yara-python vì cần trình biên dịch C. Nên bản web thật chỉ có pefile +*

hash + entropy + IoC, còn YARA chỉ chạy ở máy local. Em có ghi rõ phần này trong báo cáo.

ĐIỂM YẾU 6: Không có học máy, chỉ là luật cứng (rule-based)

Vấn đề:
Toàn bộ logic là if-else + regex cố định, không có AI học từ dữ liệu. Độ thông minh = độ "đoán trước" của người viết rule.

Trả lời thầy (lựa lời):

Em làm theo hướng luật (rule-based), không dùng học máy. Ưu điểm là dễ giải thích từng bước rõ ràng, minh bạch; nhược điểm là không tự thích nghi với biến thể mới. Nếu có thời gian, bước tiếp theo là gắn mô hình ML để tăng độ phủ.

ĐIỂM YẾU 7: Báo nhầm (false positive)

Vấn đề:
Regex quá "rộng" có thể bắt nhầm file lành (chỉ tình cờ chứa chữ eval/password). Ví dụ file JS chứa getElementById('password') bị báo nhầm là rò rỉ mật khẩu.

Trả lời thầy (lựa lời):

Dạ đúng, em có xảy ra báo nhầm khi regex không đủ chặt. Em đã hạn chế bằng cách kết hợp data-flow (chỉ báo khi dữ liệu người dùng thật sự đổ vào hàm nguy hiểm) và whitelist các chuỗi vô hại. Đánh đổi của việc "bắt mạnh" là dễ báo nhầm, nên em phải cân chỉnh ngưỡng liên tục.

CHIẾN LƯỢC TRẢ LỜI TỔNG QUÁT

Khi thầy hỏi về điểm yếu, đừng tỏ ra bối rối hay tìm cách chối. Nguyên tắc 3 bước:

1. *Thừa nhận thẳng thắn: "Dạ đúng, đây là hạn chế..."*
2. *Giải thích đúng nguyên nhân kỹ thuật (cho thấy mình hiểu sâu).*
3. *Nêu hướng khắc phục chuẩn ngành (sandbox, unpack, ML).*

Điểm mấu chốt: thầy KHÔNG trừ điểm vì hệ thống có khuyết điểm (đồ án sinh viên ai cũng có), mà trừ điểm khi sinh viên không biết khuyết điểm của chính mình. Biết và nói rõ được giới hạn chính là dấu hiệu của người hiểu đề tài sâu.

Ghi chú: Tài liệu này dùng để ôn tập trước buổi bảo vệ. Khi trả lời, hãy nói bằng giọng tự nhiên, không đọc thuộc lòng — điều quan trọng là nắm ý, không phải thuộc chữ.